



Diplomado de Ciberseguridad y Gestión de Seguridad de la Información



Módulo 1:

Introducción a la Ciberseguridad y Seguridad de la Información

Sesión 1:

Amenazas comunes en entornos digitales y Cultura de Seguridad





OBJETIVO DE LA SESIÓN:

Identificar los principales tipos de amenazas en internet, cómo actúan y cómo prevenirlos.
Reflexionar sobre la importancia de adoptar comportamientos seguros.



¿Qué es una amenaza en ciberseguridad?



Una **amenaza** es cualquier evento o acción que puede poner en riesgo la **confidencialidad, integridad o disponibilidad** de la información (Modelo CIA). Estas amenazas pueden ser:

- **Internas:** provienen de dentro de la organización (por error humano o sabotaje).
- **Externas:** provienen de atacantes o actores maliciosos fuera de la organización.

En el entorno digital, las amenazas evolucionan constantemente. A continuación, te explico las más comunes y cómo afectan al usuario promedio o a una empresa.

Phishing (Suplantación de identidad)

Es un tipo de fraude en el que un atacante se hace pasar por una entidad legítima (como un banco, universidad o empresa de tecnología) para engañar al usuario y obtener información confidencial, como contraseñas, números de tarjeta de crédito o datos personales.

¿Cómo funciona?

- El atacante envía un correo electrónico (o mensaje de texto) que parece real.
- Te pide hacer clic en un enlace y proporcionar datos personales o descargar un archivo.
- Al hacerlo, los datos van al atacante o se instala un software malicioso.

Ejemplo

Recibes un correo que dice:
"Su cuenta de Netflix fue suspendida por falta de pago. Ingrese aquí para reactivarla."

El enlace lleva a una página falsa que luce como Netflix. Al ingresar tu usuario y contraseña, se roban estos datos.

¿Cómo prevenirlo?

- Verifica el dominio del correo (ej. @netflix.com vs. @netflix-support.info)
- No hagas clic en enlaces sospechosos
- Nunca ingreses datos sensibles en sitios que no estén verificados
- Usa autenticación multifactor (MFA)



Malware (Software malicioso)

El término “malware” viene de “**malicious software**”. Es un conjunto de programas diseñados para dañar, infiltrarse, robar información o controlar un dispositivo sin que el usuario lo sepa.

Tipos principales de malware

Tipo	Qué hace	Ejemplo común
Virus	Se adhiere a archivos ejecutables y se activa cuando se abren.	Archivos de Word infectados
Gusano (Worm)	Se propaga solo a través de redes.	Propagación por correo electrónico a todos tus contactos
Troyano (Trojan)	Se presenta como un software útil, pero tiene funciones ocultas.	Un convertidor de PDF que en realidad roba archivos
Spyware	Espía lo que haces en tu equipo.	Graba teclas para robar contraseñas
Adware	Muestra publicidad excesiva o no deseada.	Pop-ups que abren páginas sin control

¿Cómo prevenirlo?

- No descargar programas de sitios desconocidos
- Usar antivirus actualizados
- Evitar conectar USBs desconocidos
- Mantener el sistema operativo al día

Analogía: Un troyano es como recibir una caja bonita (programa gratuito) que contiene una bomba (malware oculto). Parece útil, pero te perjudica al instalarlo.





Ransomware (Secuestro de información)

Es un tipo específico de malware que “**secuestra**” tu **información**: cifra (bloquea) tus archivos y exige el pago de un rescate (normalmente en criptomonedas) para recuperarlos.

¿Cómo funciona?

1. Se instala en el equipo mediante un archivo o sitio web malicioso.
2. Encripta todos los archivos importantes.
3. Aparece un mensaje exigiendo un pago (con cuenta de bitcoin) para recuperar el acceso

Ejemplo

El ransomware “WannaCry” afectó hospitales, empresas y universidades en más de 150 países. Secuestró datos críticos, y muchos no pudieron recuperarlos. Pagar el rescate **NO garantiza** que recuperarás tus archivos.

¿Cómo prevenirlo?

- Tener respaldos automáticos y en la nube
- No abrir archivos ZIP o EXE que no esperas
- No usar equipos sin antivirus en redes públicas
- Aplicar parches de seguridad (actualizaciones del sistema)





Ingeniería Social

Es el conjunto de técnicas psicológicas que un atacante utiliza para manipular a una persona y lograr que esta entregue información o acceda a sistemas sin darse cuenta.

¿Cómo funciona?

Porque explota comportamientos humanos comunes como:

- La confianza
- El miedo
- El deseo de ayudar
- La urgencia

Ejemplo

- Llamada falsa de “soporte técnico” pidiéndote tu contraseña
- Persona disfrazada de mensajero que accede al edificio sin control
- Alguien que finge necesitar ayuda para entrar a una sala restringida

¿Cómo prevenirlo?

- No entregar información sensible por teléfono, email o redes sociales
- Verificar la identidad antes de actuar
- Desconfiar de urgencias no confirmadas
- Reportar comportamientos sospechosos

Analogía: Es como un ladrón que se disfraza de plomero para entrar a tu casa, sin romper nada. En vez de vulnerar un sistema, vulnera **a la persona**.



Ataques combinados

Los atacantes combinan amenazas para lograr su objetivo. Por ejemplo:

- Envían un correo falso (phishing)
- El usuario hace clic → descarga un troyano
- El troyano abre la puerta para instalar ransomware
- Se bloquea todo el sistema y se pide rescate



Ejercicio 1: Análisis de correos simulados

En grupo los estudiantes deben identificar cuál de las 3 imágenes presentadas, Son correos falsos

José Luis Rivas

De: Iñaki Urdangarin [iurdangarin@noos.com]
Enviado el: jueves, 08 de abril de 2004 13:06
Para: jlirivas@laboratoriodeseguridadtelematica.com
Asunto: Reunión acordada

Hola José,

Despues de hablar con mi suegro me ha dicho que no hay problema, y me voy a encontrar con ellos el día 22 en el Palacio después de finalizar la audiencia.

SaluZ,
Iñaki

P.D. Recuerdos a tu familia, Cristina y yo nos acordamos mucho de las navidades pasadas. Que buenos recuerdos!!!!

Iñaki Urdangarin
Responsable de Proyectos Europeos
Instituto Noos

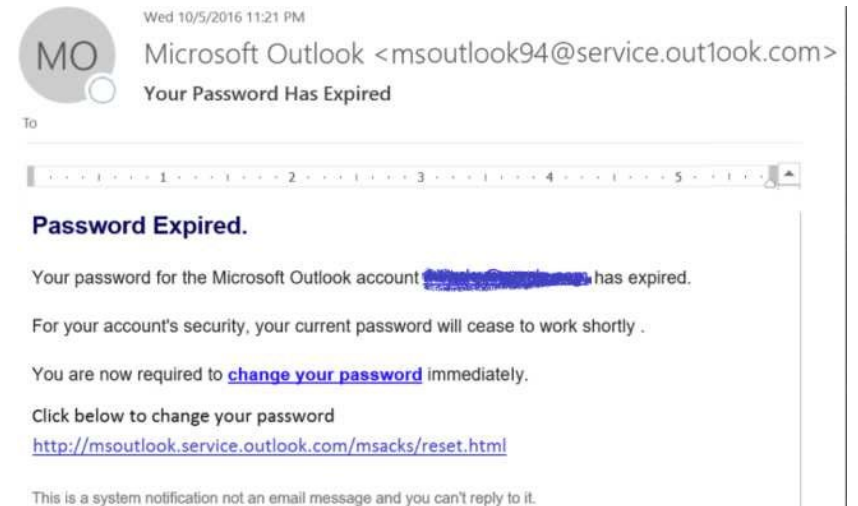


Dear User,

All Hotmail customers have been upgraded to Outlook.com. Your Hotmail Account services has expired.

Due to our new system upgrade to Outlook. In order for it to remain active follow the link Sign in Re-activate your account to Outlook. <https://account.live.com>

Thanks,
The Microsoft account team





Ejercicio 2: Caso aplicado

Situación: Recibes una llamada de alguien que dice ser del área de TI y te pide tu contraseña.

Pregunta

¿Qué harías?
¿Qué tipo de amenaza es?



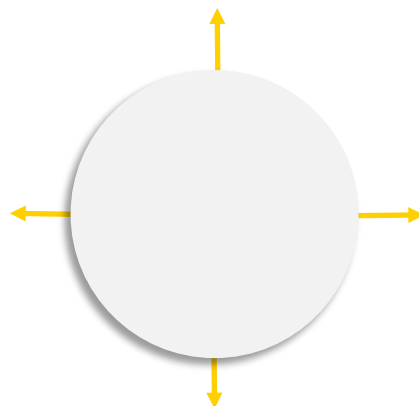


¿Qué significa “Cultura de Seguridad”?

La **cultura de seguridad de la información** es el reflejo de cómo las personas entienden, valoran y actúan frente a la protección de los datos y recursos tecnológicos. Implica no solo conocer normas y herramientas, sino **adoptar una mentalidad proactiva y responsable** sobre lo que hacemos con la información.

¿Por qué es relevante?

Porque el eslabón más débil en la ciberseguridad no es la tecnología: **somos las personas.**



Una empresa puede tener políticas perfectas en papel, pero si sus colaboradores no las aplican, son ineficaces.

95% de los incidentes de ciberseguridad están relacionados con errores humanos (según IBM, 2022).





Componentes de una Cultura de Seguridad

Componente	Explicación	Ejemplo aplicado
Conciencia	Reconocer que la seguridad es importante y que los riesgos existen.	Saber que una USB desconocida puede contener virus.
Conocimiento	Saber cómo identificar y reaccionar ante una amenaza.	Ver un correo sospechoso y no hacer clic.
Actitudes	Tener disposición a actuar con cautela, sin subestimar los riesgos.	No compartir la contraseña con un compañero.
Práctica	Aplicar comportamientos seguros como hábito.	Usar contraseña diferente para cada cuenta.
Responsabilidad colectiva	Entender que todos somos responsables de la seguridad, no solo TI.	Informar si se detecta una anomalía en la red.



¿Cómo se construye una Cultura de Seguridad?

Se construye con acciones constantes, no con una charla aislada. Ejemplos:

Capacitación periódica

Talleres,
videos,
boletines.

Ejemplos visibles

Que los líderes
practiquen y
promuevan
comportamientos
seguros.

Refuerzo positivo

Reconocer
buenas
prácticas.

Políticas claras

Guías fáciles de
entender, no
documentos
técnicos
complejos.

Buenas Prácticas Digitales

(para la vida diaria y el trabajo)

Se construye con acciones constantes, no con una charla aislada. Ejemplos:

Contraseñas

Evita

123456, contraseña,
tu nombre o fecha de
nacimiento.

Usa frases

“MiPerroCome#1KiloDe
Carne” es segura y fácil
de recordar.

Nunca la
reutilices

Cada servicio debe
tener su clave única.

Gestores de
contraseñas

Herramientas como
Bitwarden o KeePass ayudan
a generar y guardar
contraseñas seguras.

Buenas Prácticas Digitales

(para la vida diaria y el trabajo)

Se construye con acciones constantes, no con una charla aislada. Ejemplos:

Doble autenticación (MFA)

Combina algo que sabes (clave) + algo que tienes (SMS, app de autenticación).

Incluso si te roban la clave, el atacante no podrá entrar sin el segundo factor.

Buenas Prácticas Digitales

(para la vida diaria y el trabajo)

Se construye con acciones constantes, no con una charla aislada. Ejemplos:

Navegación segura

Sitios web confiables
comienzan con **https**.

Evita redes Wi-Fi abiertas sin
protección (ej. en centros
comerciales).

Desconfía de ventanas
emergentes o mensajes tipo
“¡Felicidades! Has ganado...”

Buenas Prácticas Digitales

(para la vida diaria y el trabajo)

Se construye con acciones constantes, no con una charla aislada. Ejemplos:

Actualizaciones y parches

Las actualizaciones
corrigen errores y cierran
puertas que usan los
atacantes.

No postergues la
actualización del sistema
operativo o el antivirus.

Buenas Prácticas Digitales

(para la vida diaria y el trabajo)

Se construye con acciones constantes, no con una charla aislada. Ejemplos:

Copias de seguridad

Respalda tu
información personal:
fotos, documentos,
trabajo.

Puedes usar
almacenamiento en la
nube (Google Drive,
OneDrive) o discos
externos.

Buenas Prácticas Digitales

(para la vida diaria y el trabajo)

Se construye con acciones constantes, no con una charla aislada. Ejemplos:

Cuidado con la información que compartes

↓

Todo lo que publicas en redes puede ser usado por atacantes para suplantarte.

↓

Ej.: mostrar la cédula, boletos de avión, ubicación en tiempo real, datos bancarios.

↓

Evita retos virales donde se expone información personal (nombre de tu mascota + año de nacimiento, etc.).



Prácticas en entornos organizacionales

En una empresa, universidad o institución, la cultura de seguridad debe ser una política transversal, no algo exclusivo del área de TI.

¿Qué se espera de cada área?

Área	Rol en la seguridad
Dirección	Establecer políticas, promover el ejemplo
Administrativos	Gestionar documentos e información con controles de acceso
Estudiantes/Empleados	Cumplir las normas y reportar anomalías
Soporte TI	Aplicar controles técnicos, monitorear la red
Comunicaciones	Asegurar el uso responsable de canales digitales





Prácticas en entornos organizacionales

En una empresa, universidad o institución, la cultura de seguridad debe ser una política transversal, no algo exclusivo del área de TI.

Política de uso aceptable

Todo entorno laboral debe contar con una política de “Uso Aceptable de Recursos”, que cubra aspectos como:

Qué está permitido y qué no en el uso del correo, internet, dispositivos USB.

Protocolos de respuesta ante incidentes.

Normas sobre el uso de redes sociales desde el trabajo.





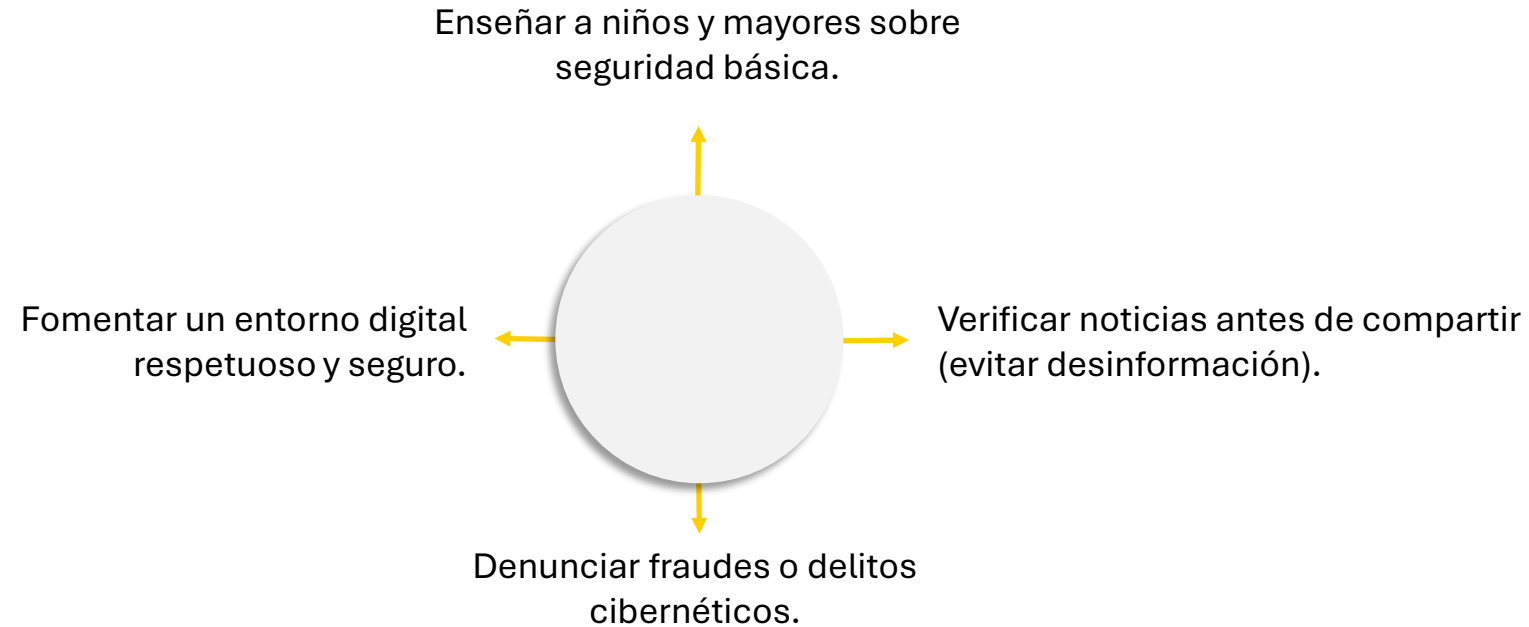
Conductas de riesgo que debilitan la cultura de seguridad

Conducta insegura	Consecuencia
Anotar la clave en un post-it	Cualquiera puede acceder
Dejar la sesión abierta al irse del escritorio	Robo de información
Enviar archivos sensibles por WhatsApp	No hay cifrado ni control
Ignorar alertas del antivirus	Riesgo de malware activo
Reírse del phishing porque “eso no me pasa”	Vulnerabilidad por exceso de confianza



Rol ciudadano en la era digital

Incluso si no trabajas en una empresa o institución, como ciudadano digital tienes responsabilidades:





Ejercicio 3: Política personal de seguridad

A partir de lo aprendido en el módulo, redacta una política personal de seguridad digital en la que especifiques al menos cinco compromisos o prácticas que aplicarás en tu vida diaria (como estudiante, trabajador o ciudadano digital). Puedes usar la plantilla entregada o escribirla desde cero, pero asegúrate de que sea concreta, realista y aplicable.

